CONFIDENTIAL SECURITY DOCUMENT

Penetration Test Report

Example Corp Customer Portal

Prepared for the Example Corp Security Team

`app.example.com`

Assessment Type	Black-Box Web Application & API Penetration Test
Assessment Target	`app.example.com`
Report Date	1 January 2030
Report Status	**Draft**
Overall Risk Rating	CRITICAL
Classification	**Confidential — Restricted Distribution**

Distribution: This document contains sensitive security information and must not be shared outside of authorised personnel responsible for remediation of the identified findings.

Disclaimer: Testing was conducted under written authorisation against the designated test environment. All activities were performed in a controlled manner to minimise operational disruption; no records were modified or deleted beyond what was necessary to confirm a finding.

Warning: If this report documents live credentials or other secrets valid at the time of testing, they must be rotated immediately upon receipt of this report, and circulation should be restricted to personnel directly responsible for remediation.

1

1 Table of Contents 1

2 Executive Summary 2
2.1 Overview . . . 2
2.2 Overall Risk Rating . . . 2
2.3 Findings by Severity . . . 2
2.4 Remediation Roadmap (priorities) . . . 3

3 Scope & Methodology 4
3.1 In-Scope Assets . . . 4
3.2 Out of Scope . . . 4
3.3 Rules of Engagement . . . 4
3.4 Methodology . . . 4
3.5 Severity Definitions . . . 5

4 Target Environment 6

5 Attack Path Summary 7

6 Technical Findings 8
6.1 F-01 — [FILL: Short, specific finding title, e.g. "Unauthenticated SQL Injection in the /search Endpoint"] . . . 9
6.1.1 Description . . . 9
6.1.2 Steps to Reproduce . . . 9
6.1.3 Impact . . . 9
6.1.4 Remediation . . . 10
6.2 F-02 — [FILL: Short, specific finding title, e.g. "Missing Rate Limiting on Login Endpoint"] . . . 11
6.2.1 Description . . . 11
6.2.2 Steps to Reproduce . . . 11
6.2.3 Impact . . . 11
6.2.4 Remediation . . . 11

7 Demonstrated Impact 12

8 Recommendations 13

9 Appendix A — Tools Used 14

10 Appendix B — Finding Index 14

2 Executive Summary

Overview

A black-box penetration test was conducted against Example Corp — app.example.com to identify security weaknesses that could be exploited by an external attacker. Testing covered the public web application, its supporting REST API, and any authenticated functionality reachable with the credentials supplied by the client.

The assessment identified [FILL: N] **distinct findings**. The application's overall security posture is [FILL: overall risk word, e.g. critical / high / moderate]: [FILL: one-sentence summary of the worst realistic outcome, e.g. "an unauthenticated attacker can read and modify any user's data"].

CRITICAL — Key Takeaway

Result — [FILL: one-line verdict].

Headline conclusions:

- [FILL: Headline finding 1]
- [FILL: Headline finding 2]
- [FILL: Headline finding 3]
- [FILL: N of M findings require no authentication.]

Overall Risk Rating

CRITICAL

Findings by Severity

Severity	Count	Meaning
CRITICAL	[FILL: n]	[FILL: What a Critical finding means for this engagement]
HIGH	[FILL: n]	[FILL: What a High finding means for this engagement]
MEDIUM	[FILL: n]	[FILL: What a Medium finding means for this engagement]
LOW	[FILL: n]	[FILL: What a Low finding means for this engagement]
Total	[FILL: N]	[FILL: N unauthenticated]

Remediation Roadmap (priorities)

Priority	Action
P1 — Immediate	[FILL: The single most urgent fix]
P2 — Short-term	[FILL: Systemic fixes that close whole classes of issues]
P3 — Hardening	[FILL: Defence-in-depth / hygiene improvements]

3 Scope & Methodology

In-Scope Assets

Asset	Notes
app.example.com	[FILL: Primary web application]
api.example.com	[FILL: REST API backing the application]

Out of Scope

- [FILL: Anything explicitly excluded by the rules of engagement]

Rules of Engagement

- Testing window: [FILL: start date] – [FILL: end date].
- Testing was performed from [FILL: source IP(s) / VPN].
- Denial-of-service and destructive testing were [FILL: in / out of] scope.
- Test accounts supplied: [FILL: role(s) and count].

Methodology

Testing followed a standard black-box methodology, broadly aligned with the OWASP Web Security Testing Guide and OWASP API Security Top 10:

1. **Reconnaissance.** Passive and active enumeration of the attack surface (subdomains, endpoints, technologies, exposed files).
2. **Mapping.** Manual crawl and API-endpoint discovery to build a full inventory of authenticated and unauthenticated functionality.
3. **Vulnerability identification.** Manual testing supplemented by tooling (e.g. Burp Suite, `sqlmap`, `nuclei`) across the OWASP Top 10 classes.
4. **Exploitation & impact validation.** Each candidate finding was manually verified end to end, with impact demonstrated non-destructively.
5. **Reporting.** Findings were triaged by severity (CVSS v3.1) and written up with evidence, impact, and remediation guidance.

Severity Definitions

Level	Definition
CRITICAL	Unauthenticated RCE, unauthenticated SQL injection, or authentication bypass.
HIGH	Authenticated RCE/SQLi, stored XSS, IDOR exposing sensitive data, upload-to-RCE.
MEDIUM	Reflected XSS, CSRF, missing session hardening, sensitive data exposure.
LOW / Info	Hygiene and defence-in-depth gaps.

4 Target Environment

Component	Detail
Web / app server	[FILL: e.g. nginx 1.25, Apache Tomcat 9]
Application stack	[FILL: e.g. Node.js / Express, Spring Boot, Django]
Database	[FILL: e.g. PostgreSQL 15]
Authentication	[FILL: e.g. session cookie, JWT bearer token]

[FILL: Optional short paragraph describing anything notable about the deployment that is relevant context for the findings below (e.g. a CDN/WAF in front of the origin, multi-tenant architecture, third-party integrations).]

5 Attack Path Summary

[FILL: Optional section: if several findings chain together into a single compelling attack path (e.g. unauthenticated SQLi -> credential extraction -> admin login -> RCE), summarise that chain here in prose or as a short numbered list, cross-referencing the finding IDs. Delete this section if every finding stands alone.]

1. [FILL: Step 1, with a reference to the finding that enables it]
2. [FILL: Step 2]
3. [FILL: Step 3 - final impact]

6 Technical Findings

F-01 — [FILL: Short, specific finding title, e.g. "Unauthenticated SQL Injection in the /search Endpoint"]

Finding Metadata			
ID	F-01	**Severity**	**CRITICAL**
Affected Endpoint	/api/v1/search?q=	**Exploitability**	[FILL: Trivial / Moderate / Difficult]
CVSS Score	[FILL: 9.8 (Critical)]	**Authentication**	[FILL: None / Authenticated]
Category	[FILL: SQL Injection (CWE-89)]	**Remediation Priority**	[FILL: Immediate]

Description

[FILL: Describe the vulnerable endpoint/parameter, what it does normally, and how untrusted input reaches the sink without proper validation or parameterisation.]

Steps to Reproduce

1. [FILL: Step 1 - e.g. send a baseline request and note the normal response.]

[FILL: screenshot placeholder - replace with \includegraphics once you add the image under images/]

Figure 1: [FILL: Baseline: normal response from the endpoint]

2. [FILL: Step 2 - e.g. supply the payload and note the changed behaviour.]
3. [FILL: Step 3 - e.g. confirm and characterise with tooling.]

Impact

CRITICAL — Key Takeaway

[FILL: One tight paragraph: what an attacker can concretely do as a result of this finding, stated in business terms (data exposed, systems reachable, accounts takeover-able), and how it relates to any other finding it chains with.]

Remediation

- [FILL: The specific code/config fix, e.g. "use parameterised queries / an ORM everywhere this pattern occurs".]
- [FILL: A defence-in-depth control, e.g. least-privilege DB account, WAF rule as an interim mitigation.]

F-02 — [FILL: Short, specific finding title, e.g. "Missing Rate Limiting on Login Endpoint"]

Finding Metadata			
ID	F-02	**Severity**	**MEDIUM**
Affected Endpoint	/api/v1/login	**Exploitability**	[FILL: Moderate]
CVSS Score	[FILL: 5.3 (Medium)]	**Authentication**	[FILL: None]
Category	[FILL: Improper Restriction of Excessive Authentication Attempts (CWE-307)]	**Remediation Priority**	[FILL: Short-term]

Description

[FILL: Describe the gap and why it matters - e.g. no lockout/backoff after repeated failed login attempts, enabling credential stuffing / brute force.]

Steps to Reproduce

1. [FILL: Sent N consecutive invalid login attempts for the same account.]
2. [FILL: Observed no lockout, CAPTCHA, or backoff after N attempts.]

Impact

HIGH — Impact Statement

[FILL: What this enables in practice - e.g. credential stuffing against a list of known-breached passwords, or brute-forcing low-entropy PINs/OTPs.]

Remediation

- [FILL: Add account lockout / exponential backoff after N failed attempts.]
- [FILL: Add CAPTCHA or equivalent bot mitigation on repeated failures.]
- [FILL: Alert on anomalous login-attempt volume.]

7 Demonstrated Impact

[FILL: One or two paragraphs summarising the concrete impact that was demonstrated (not just theoretical) during the engagement, tying back to the finding IDs.]

Data / Access	How it was demonstrated
[FILL: e.g. Customer PII]	[FILL: via F-01]
[FILL: e.g. Admin session]	[FILL: via F-02 + F-03 chained]

8 Recommendations

Priority	Recommendation
Immediate	[FILL: Fix that removes the worst finding(s)]
Short-term	[FILL: Systemic fix closing a whole class of issues]
Long-term	[FILL: Process / hardening improvement, e.g. SAST/DAST in CI, secret scanning]

[FILL: Optional closing paragraph offering to support retesting once fixes are deployed.]

9 Appendix A — Tools Used

- [FILL: e.g. Burp Suite Professional]
- [FILL: e.g. sqlmap]
- [FILL: e.g. nuclei + custom templates]

10 Appendix B — Finding Index

ID	Title	Severity
F-01	[FILL: Title]	CRITICAL
F-02	[FILL: Title]	MEDIUM